

Rendu de groupe — Contribution individuelle

Cyber Trust

Mahamadou DIACOUMBA
Analyste SOC

Exploitation SOC · Playbooks · Qualification · REX · Procédures lab

Établissement	Sup de Vinci — Mastère 2 Cybersécurité
Équipe	Cyber Trust
Auteur	Mahamadou DIACOUMBA — Analyste SOC
Année	2025 — 2026

Introduction — Positionnement dans l'équipe Cyber Trust

Ce document constitue la contribution individuelle de Mahamadou DIACOUMBA au rendu de groupe de l'équipe Cyber Trust, dans le cadre du Mastère 2 Cybersécurité 2025-2026 (Sup de Vinci).

Au sein de l'équipe, j'ai occupé le rôle d'Analyste SOC. Ma mission consistait à opérationnaliser le centre de supervision de sécurité externalisé pour le client fictif Daylight, un réseau d'une trentaine de sites audioprothésistes. Concrètement, cela recouvre quatre domaines : la rédaction des playbooks de réponse aux incidents, la qualification opérationnelle des alertes générées par le SIEM Wazuh, la production de retours d'expérience (REX) sur les scénarios simulés, et la formalisation des procédures d'exploitation et de support lab.

L'infrastructure SOC repose sur une zone dédiée (10.10.50.0/24) isolée du reste du réseau Daylight par des règles pfSense strictes (règles 110010 et 110020). Wazuh Manager, Indexer et Dashboard y sont déployés, avec des agents sur les machines des zones USERS, SERVERS et DMZ. Les alertes sont corrélées selon le framework MITRE ATT&CK et les incidents critiques sont transmis via TheHive/Shuffle/Cortex pour une réponse coordonnée.

Les sections suivantes détaillent l'ensemble de ces livrables opérationnels.

Playbooks de réponse aux incidents

Les playbooks constituent le livrable opérationnel central de ma contribution. Ils transforment une alerte brute en une séquence d'actions documentées et reproductibles, que l'analyste peut suivre étape par étape même sous pression. J'ai rédigé un playbook par scénario de menace identifié, en respectant à chaque fois la même logique : identifier la source, vérifier le contexte, qualifier l'impact, contenir si nécessaire, documenter.

Playbook 1 — Brute Force SSH

Déclencheur : plus de 5 échecs d'authentification SSH en 60 secondes depuis une même IP.
Tactique MITRE : T1110 — Credential Access.

Étape	Action SOC	Détail opérationnel
1	Identifier la source	Récupérer l'IP source dans Wazuh. Vérifier si elle appartient à la plage USERS (10.10.10.0/24) ou est externe. Croiser avec les logs pfSense pour confirmer que le flux est arrivé.
2	Vérifier le compte visé	Identifier le compte SSH cible (service, admin ou utilisateur standard). Vérifier le statut actuel du compte dans l'AD : actif, verrouillé, suspect ?
3	Qualifier l'impact	Le compte a-t-il été compromis ? Chercher dans Wazuh les connexions SSH réussies depuis la même IP dans les 10 minutes suivant l'alerte.
4	Bloquer / Isoler	Source externe : demande d'ajout d'une règle de blocage pfSense. Source interne : isolation logique du poste (VLAN quarantaine). Désactivation du compte si compromission confirmée.
5	Documenter	Créer un ticket incident, horodater chaque action. Si compromission confirmée : notification à la direction. Produire un REX en fin de traitement.

Playbook 2 — Accès anormal dossier patient

Déclencheur : volume d'accès supérieur à 50 fichiers en 5 minutes sur /data/patients/, ou accès depuis un compte non habilité. Tactique MITRE : T1005 — Collection.

Étape	Action SOC	Détail opérationnel
1	Identifier l'utilisateur	Récupérer le compte ayant déclenché l'alerte auditd. Vérifier dans l'annuaire si ce compte a une habilitation sur les dossiers patients concernés.
2	Analyser le volume	Combien de fichiers consultés ou copiés ? Sur quelle durée ? Y a-t-il eu une connexion réseau sortante simultanée laissant supposer une exfiltration ?
3	Vérifier le contexte métier	Contacter le responsable du centre : l'action est-elle légitime (migration, audit interne, dépannage) ou anormale ?
4	Qualifier et réagir	Action légitime : journaliser et clôturer. Action suspecte : suspension du compte, préservation des preuves (logs auditd), notification DPO si données personnelles potentiellement compromises.
5	Escalader si RGPD	Si violation de données personnelles avérée : notification CNIL obligatoire dans les 72 heures. Escalade vers la direction du réseau Daylight.

Playbook 3 — Élévation de privilèges

Déclencheur : commande sudo non autorisée, modification de /etc/sudoers, ou ajout à un groupe privilégié. Tactique MITRE : T1548 — Privilege Escalation.

Étape	Action SOC	Détail opérationnel
1	Identifier l'action	Quelle commande a déclenché l'alerte (sudo, su, ajout groupe, modification sudoers) ? Sur quel système et depuis quel compte ?
2	Vérifier la légitimité	L'action a-t-elle été demandée via un ticket de changement ? L'équipe technique a-t-elle effectué une opération administrative ce jour ? Contacter directement.
3	Évaluer la persistance	L'élévation a-t-elle abouti ? Des modifications permanentes ont-elles été effectuées (nouveau sudo, crontab, service créé) ? Vérifier l'état du système.
4	Contenir	Suppression des droits ajoutés illégitimement, réinitialisation du mot de passe du compte concerné, vérification des autres systèmes pour propagation éventuelle.
5	Documenter et affiner	Si faux positif (admin légitime non déclaré) : mettre à jour le processus de gestion des changements. Ajouter le compte à la liste blanche si action récurrente légitime.

Playbook 4 — Tentative de mouvement latéral (pfSense MGMT/SOC)

Déclencheur : connexion bloquée par pfSense depuis USERS vers MGMT (10.10.40.x) ou SOC (10.10.50.x), visible via règles 110010/110020. Tactique MITRE : T1021 — Lateral Movement.

Étape	Action SOC	Détail opérationnel
1	Identifier source et destination	Lire l'alerte Wazuh issue de la règle pfSense 110020. Identifier l'IP source (zone USERS), la destination (MGMT ou SOC) et le port visé.
2	Analyser le poste source	Ce poste est-il un poste audioprothésiste standard ? A-t-il récemment été utilisé par un tiers ? Croiser avec les logs de connexion de la zone USERS.
3	Évaluer la menace	Tentative isolée : erreur de configuration probable. Tentatives répétées depuis le même poste : signal fort d'un attaquant actif ou d'un poste compromis.
4	Renforcer la surveillance	pfSense bloque déjà le flux. Augmenter le niveau d'alerte sur les événements issus de cette IP. Envisager une isolation du poste si les tentatives continuent.
5	Documenter	Conserver impérativement cet événement : c'est la preuve que la segmentation réseau fonctionne et que le SOC détecte les mouvements latéraux. Produire un rapport de détection pour Daylight.

Qualification opérationnelle des alertes

Une alerte brute n'est pas un incident : c'est un signal qui doit être interprété dans son contexte pour décider de l'action appropriée. La qualification est l'étape la plus difficile à formaliser parce qu'elle ne se réduit pas à l'application d'une règle — elle demande du jugement. Trop réagir sur des faux positifs dégrade la confiance dans le SOC ; ignorer un vrai incident peut avoir des conséquences graves, notamment pour des données patients soumises au RGPD.

Dans ce projet, j'ai structuré la qualification autour de trois questions fondamentales à poser face à chaque alerte. Première question : l'action détectée est-elle techniquement cohérente avec ce contexte réseau ? Un brute force SSH depuis la zone USERS vers un serveur interne est plausible ; le même brute force depuis l'interface pfSense est très suspect. Deuxième question : ce comportement est-il habituel pour ce compte, ce système, à cette heure ? Un audioprothésiste qui consulte cinquante dossiers un lundi matin après le week-end n'est pas forcément suspect ; le même comportement à 3h du matin l'est beaucoup plus. Troisième question : quel est l'impact potentiel si c'est un vrai incident — y a-t-il des données patients en jeu ?

Niveaux de sévérité retenus

Niveaux 3 à 6 : Informatif — à journaliser, pas d'action immédiate requise

Niveaux 7 à 9 : Attention — à investiguer dans les 4 heures

Niveaux 10 à 12 : Alerte — investigation immédiate, application du playbook

Niveaux 13+ : Critique — escalade obligatoire, activation PCA si nécessaire

En pratique, les alertes se répartissent en quatre catégories. Les faux positifs confirmés — l'action est techniquement détectable mais parfaitement légitime — se clôturent après documentation et ajout d'une exception contextuelle dans la règle. Les actions légitimes non déclarées, comme un administrateur qui fait une élévation de privilèges sans ticket de changement, se traitent par la sensibilisation et l'amélioration du processus. Les incidents avérés mineurs, sans compromission confirmée, s'instruisent en appliquant le playbook avec surveillance renforcée. Les incidents majeurs impliquant des données patients ou une compromission avancée déclenchent l'escalade immédiate vers la direction, le DPO et potentiellement la CNIL.

REX — Retour d'expérience par scénario

Après chaque simulation de scénario en laboratoire, j'ai produit un retour d'expérience. L'objectif n'est pas de célébrer ce qui a fonctionné, mais de comprendre honnêtement ce qui aurait pu être mieux et d'en tirer des actions correctives concrètes.

REX 1 — Brute Force SSH

Scénario simulé : dix tentatives SSH échouées depuis un poste de la zone USERS vers serveur-01. L'alerte Wazuh a été générée dès le cinquième échec, au niveau 10, et visible dans le dashboard en moins d'une minute. Ce qui a bien fonctionné : la détection est rapide et le seuil est adapté au contexte. La limite principale identifiée est l'absence de blocage automatique de l'IP source — l'action reste manuelle, ce qui peut représenter plusieurs minutes de délai. À terme, l'intégration de l'Active Response Wazuh permettrait de remonter automatiquement une demande de blocage vers pfSense sans intervention humaine. Enseignement général : la rapidité de réaction est aussi importante que la détection elle-même.

REX 2 — Accès anormal dossier patient

Scénario simulé : accès à soixante fichiers patients en trois minutes depuis un compte standard non habilité. L'alerte a été correctement générée via auditd et visible dans Wazuh. Ce qui a bien fonctionné : la corrélation entre le volume d'accès et l'heure a permis une détection pertinente. La limite principale : impossible de déterminer si les fichiers ont été copiés ou seulement lus, faute d'outil DLP intégré. Cette absence rend difficile la qualification entre accès anormal et exfiltration réelle. L'action corrective envisagée est l'intégration d'une solution de surveillance des flux sortants. Enseignement : détecter un comportement anormal nécessite de connaître la normale — une baseline comportementale manque ici.

REX 3 — Élévation de privilèges

Scénario simulé : ajout d'un compte utilisateur au groupe sudo depuis un compte non habilité. L'alerte Wazuh issue de la règle auditd sur /etc/sudoers a été immédiate, au niveau 10, avec le nom du compte clairement identifié dans l'alerte. Ce qui a bien fonctionné : détection rapide et contexte lisible directement dans l'alerte. La limite : la règle a également déclenché une alerte lors d'une opération administrative légitime non déclarée de l'équipe, générant un faux positif. L'action corrective est la mise en place d'une liste blanche des comptes admins autorisés à effectuer des élévations sans alerte. Enseignement : une règle trop sensible génère du bruit qui fatigue les analystes et dégrade la qualité du triage.

REX 4 — Mouvement latéral pfSense MGMT/SOC

Scénario simulé : tentative de connexion HTTP depuis un poste USERS (10.10.10.15) vers l'interface de gestion pfSense (10.10.40.1). Le flux a été bloqué par pfSense et l'événement est remonté dans Wazuh via le syslog en quelques secondes avec la règle 110020. C'est le scénario où la chaîne complète a été la mieux démontrée : segmentation réseau, blocage pfSense, journalisation syslog et alerte SOC. La limite identifiée est que l'alerte mentionne une adresse IP mais pas le nom du poste ni de l'utilisateur connecté, ce qui oblige à une recherche manuelle supplémentaire dans l'AD. Enrichir les alertes pfSense avec les informations DHCP ou Active Directory résoudrait ce problème. Enseignement général : la qualité d'une alerte détermine directement la rapidité de l'investigation.

Procédures d'exploitation et support lab

Pour que les scénarios puissent être testés et les preuves capturées dans de bonnes conditions, le lab doit être en état de fonctionner à chaque session de travail. J'ai contribué au maintien opérationnel de l'environnement en établissant une procédure de vérification en début de session et une procédure de reprise en cas de panne.

Procédure de vérification en début de session

La vérification suit un ordre logique, du composant central vers les périphériques. On commence par s'assurer que le Wazuh Manager est actif en exécutant `systemctl status wazuh-manager` sur la VM SOC. On vérifie ensuite que l'Indexer et le Dashboard sont accessibles en HTTPS sur 10.10.50.10 — un timeout à cette étape signale généralement un problème de ressources sur la VM. On contrôle dans le Dashboard que tous les agents endpoint sont bien en statut Active ; un agent Disconnected bloque les tests du scénario correspondant. On confirme que serveur-01 répond au ping et accepte les connexions SSH depuis la zone SERVERS, et que les logs pfSense arrivent bien dans Wazuh en filtrant les événements issus de pfsense-fw-01.

Enfin, un test fonctionnel de bout en bout est obligatoire avant toute démonstration : lancer six tentatives SSH échouées sur serveur-01 et vérifier que l'alerte de brute force remonte dans le Dashboard Wazuh en moins de deux minutes au niveau 10 ou plus. Si ce test échoue, la session de démonstration est reportée jusqu'à résolution du problème.

Procédure de reprise en cas de panne

En cas de dysfonctionnement d'un composant, la procédure de reprise suit quatre étapes. Premièrement, vérifier que la VM correspondante est bien démarrée dans l'hyperviseur et qu'elle dispose des ressources nécessaires (RAM, disque). Deuxièmement, relancer le service `systemd` concerné (`wazuh-manager`, `wazuh-indexer` ou `wazuh-dashboard`) et consulter ses logs pour identifier la cause de la panne. Troisièmement, si le service redémarre mais le comportement reste anormal, vérifier les fichiers de configuration et comparer avec la version de référence. Quatrièmement, si le problème persiste, restaurer la VM depuis le snapshot stable le plus récent. Les snapshots sont nommés avec la date et l'état du lab — par exemple `wazuh-soc-stable-20251201` — pour retrouver rapidement le bon point de reprise sans risquer de perdre des configurations récentes.

Support aux scénarios de test

Ma contribution au support lab inclut également la préparation des environnements de test pour chaque scénario. Pour le brute force SSH, un script de simulation génère le bon nombre de tentatives échouées depuis l'IP souhaitée. Pour l'accès anormal aux dossiers patients, un compte de test avec les droits appropriés est préparé et le répertoire `/data/patients/` est peuplé de fichiers représentatifs. Pour l'élévation de privilèges, le compte de test est configuré sans droits `sudo` initialement. Pour le mouvement latéral, le poste source est positionné dans la bonne zone USERS et la tentative de connexion vers MGMT est scriptée. Cette préparation garantit la reproductibilité des démonstrations et évite les imprévus lors des présentations.